

IT Security Basics

Password Security, MFA and Access Control

Authentication

- Identification
  - A person presents its identity to tell who he/she is
  - E.g. presenting username, e-mail address, etc.
- Authentication
  - A person gives a proof that he/she really is who he/she says
  - E.g. presenting password, fingerprint, etc.
- Authorization
  - Checking which permissions the given identity have
  - E.g. accessing banking system is allowed but not the access to any network hardware like routers



Source: https://regulaforensics.com/blog/types-of-authentication/

Password Security

FH University of Applied Sciences TECHNIKUM WIEN

Password Security



Source: https://blog.teknologize.com/a-password-is-like-a-toothbrush

Password Rules

- Secure Passwords…
  - Are sufficiently long! (at least 12 characters, thanks to AI)
  - Are alphanumeric (A-Z, a-z, 0-9)
  - Contain special characters <§$%&/()=?
  - Are **NEVER** stored in plaintext
  - Are **NEVER** transmitted in plaintext
  - Change regularly (good or bad? What do you think?)
  - Are different for each account
  - Do not contain personal information
  - Are no default passwords like 1234 or passw0rd



Source: https://www.ssbwyo.bank/wp-content/uploads/2023/09/Tips-For-Creating-Strong-Passwords.jpg

Password Rules

- Why are these rules so important?



Time It Takes Using AI to Crack Your Password [2023]

# OF CHARACTER	Numbers Only	Lowercase Letters	Lowercase Upper & Letters	Numbers, Upper & Lowercase Letters	Numbers, Upper & Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	Instantly	Instantly	Instantly
6	Instantly	Instantly	Instantly	Instantly	4 Seconds
7	Instantly	Instantly	22 Seconds	42 Seconds	6 Minutes
8	Instantly	3 Seconds	19 Minutes	48 Minutes	7 Hours
9	Instantly	1 Minutes	11 Hours	2 Days	2 Weeks
10	Instantly	1 Hours	4 Weeks	6 Months	5 Years
11	Instantly	23 Hours	4 Years	38 Years	356 Years
12	25 Seconds	3 Weeks	289 Years	2K Years	30K Years
13	3 Minutes	11 Months	16K Years	91K Years	2M Years
14	36 Minutes	49 Years	827K Years	9M Years	187M Years
15	5 Hours	890 Years	47M Years	613M Years	14Bn Years
16	2 Days	23K Years	2Bn Years	26Bn Years	1Tn Years
17	3 Weeks	812K Years	539.72M Years	2Tn Years	95Tn Years
18	10 Months	22M Years	7.23Bn Years	96Tn Years	6Qn Years



TIME IT TAKES A HACKER TO BRUTE FORCE YOUR PASSWORD IN 2024

How did we make this? Learn at hivesystems.com/password

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	3 secs	6 secs	9 secs
5	Instantly	4 secs	2 mins	6 mins	10 mins
6	Instantly	2 mins	2 hours	6 hours	12 hours
7	4 secs	50 mins	4 days	2 weeks	1 month
8	37 secs	22 hours	8 months	3 years	7 years
9	6 mins	3 weeks	33 years	161 years	479 years
10	1 hour	2 years	1k years	9k years	33k years
11	10 hours	44 years	89k years	618k years	2m years
12	4 days	1k years	4m years	38m years	164m years
13	1 month	29k years	241m years	2bn years	11bn years
14	1 year	766k years	12bn years	147bn years	805bn years
15	12 years	19m years	652bn years	9tn years	56tn years
16	119 years	517m years	33tn years	566tn years	3qd years
17	1k years	13bn years	1qd years	35qd years	276qd years
18	11k years	350bn years	91qd years	2qn years	19qn years

HIVE SYSTEMS

› Hardware: 12 x RTX 4090 | Password hash: bcrypt

Sources: https://www.labyrinthit.com/the-threat-of-ai-powered-password-cracking-your-passwords-at-risk/
https://www.hivesystems.com/blog/are-your-passwords-in-the-green

Password Entropy

- Strength of passwords calculable via entropy
- Entropy = information content of a character string
- Entropy represents a measure of the "disorder" of a text
- Represented by Greek capital letter H (Eta) - measured in bit
- Entropy $H = b*\log_2(a)$
  - a = character set
  - b = length of character string
- Example: a = {1,2,3,a,b,c}, b = 4
- Possible combinations: $6^4 \Rightarrow 1296 \Rightarrow$ Entropy **H = 10.33 bit**

Password Entropy based on the password rules

- Character set a = 102
  - Lower case a-z: 26
  - Upper case A-Z: 26
  - Numbers 0-9: 10
  - Special characters German keyboard: 40
- Password length b = 8

- $H = b*\log2(a) \Rightarrow H = 8*\log_2(102) \Rightarrow$ Entropy of 53.37 bit

Password Entropy other common examples

- PIN CODE [0-9]
  - Character set a = 10, length = 4 ⇒ entropy of 13.28 bit
- PIN CODE [0-9]
  - Character set a = 10, length = 10 ⇒ entropy of 33.22 bit

- Wanted: The entropy of a 10-character password made up of special characters and numbers.
- Wanted: The entropy of a 12-character password from the HEX alphabet.

Example Brute Force Attack

- Possible combinations = number of characters $^{\text{Password length}}$
- **Example:** PW length = 4, number of characters = 102
  Combinations = 108243216

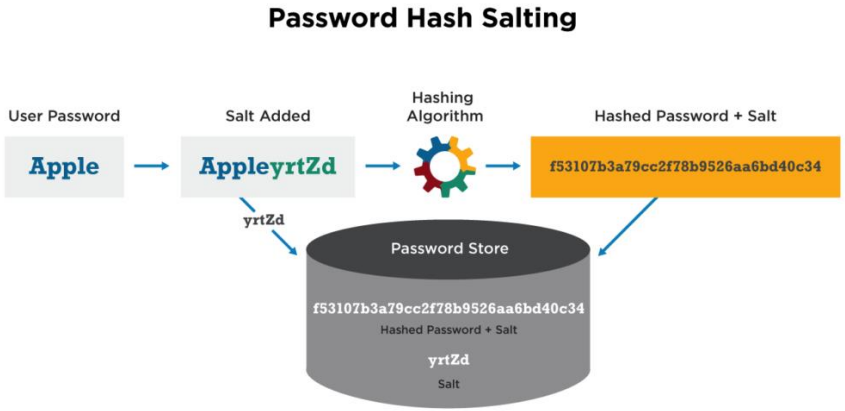
  10.000 Key/s ⇒108243216 / 10000 = 625s **~ 125 minutes**

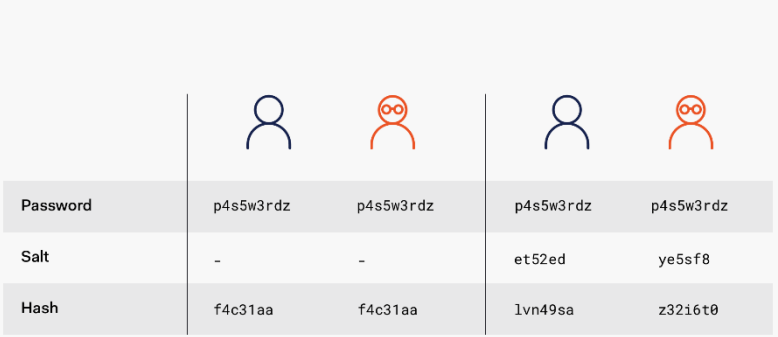
- **Example:** PW length = 8 , number of characters = 102
  Combinations = 11716593810022656

  100,000 Key/s ⇒Time = 1171659381002265**6** / 100000 = 11716593810**0s**
  ~ 3715 years
- The keyspace must be tested 50% to reach the statistical probability of a hit

How to Store passwords

- NEVER store passwords in cleartext
- Store passwords as hash-values
- Additional: Usage of Salt or Pepper
- Salt:
  - Individual random value added to the password before hashing it
  - Prevent same hash for same passwords
  - Harder to crack passwords with rainbow tables
- Pepper:
  - Identical random value for all passwords





Password	p4s5w3rdz	p4s5w3rdz	p4s5w3rdz	p4s5w3rdz
Salt	-	-	et52ed	ye5sf8
Hash	f4c31aa	f4c31aa	lvn49sa	z32i6t0

Sources: https://auth0.com/blog/adding-salt-to-hashing-a-better-way-to-store-passwords/
https://cyberhoot.com/cybrary/password-salting/

Multifactor Authentication

FH University of Applied Sciences TECHNIKUM WIEN

Mulitfactor Authentication (MFA)

- MFA = Measurement to make authentication more secure
- Uses more than one factor for authentication
  - Combines more than one method for authentication

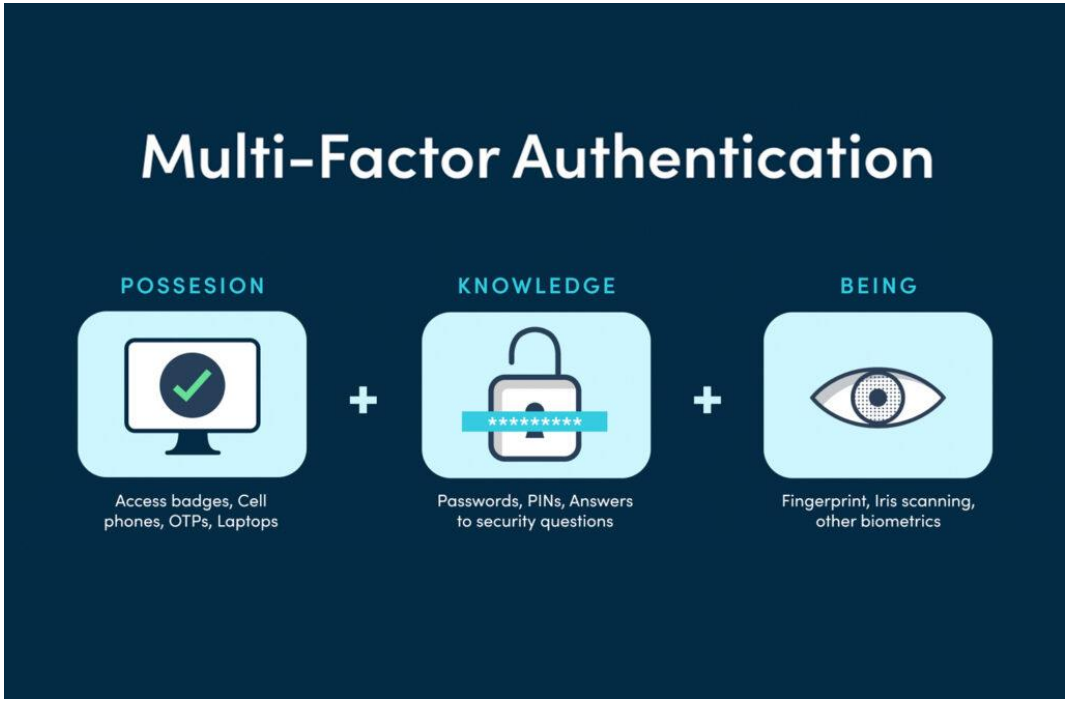
- Reasons:
  - Classical Login: username and password not state of the art any longer
  - Passwords are too vulnerable

Mulitfactor Authentication (MFA)

- Dangers for passwords:
  - Offline Dictionary Attacks: An attacker gains access to the password file and compares the stored password hashes with hashes of common passwords to find a match
  - Popular Password Attacks: Attackers try commonly used passwords across multiple accounts
  - Exploiting User Mistakes: Mistakes include writing down passwords, sharing them, or falling for social engineering
  - Electronic Monitoring: Passwords sent over a network can be intercepted
  - Brute Force Attacks: Try and error to find out a password
  - Sniffing: Using a password sniffer on software or hardware
  - Unencrypted network traffic: Often a problem in public WLAN like e.g. ÖBB or internet coffee

Mulitfactor Authentication (MFA)

- MFA uses more than one factor for authentication
  - Something you know
    - E.g. Password or PIN
  - Something you have
    - E.g. ID-Card or Certificate
  - Something you are
    - E.g. Fingerprint or Face detection
    - Including something you do like e.g. typing behavior or voice pattern



Source: https://www.brightlinktech.com/2022/03/11/the-benefits-of-multi-factor-authentication/

Access Control

FH University of Applied Sciences TECHNIKUM WIEN

Access Control

"Prevention of unauthorized use of a resource, including the prevention of use of a resource in an unauthorized manner".

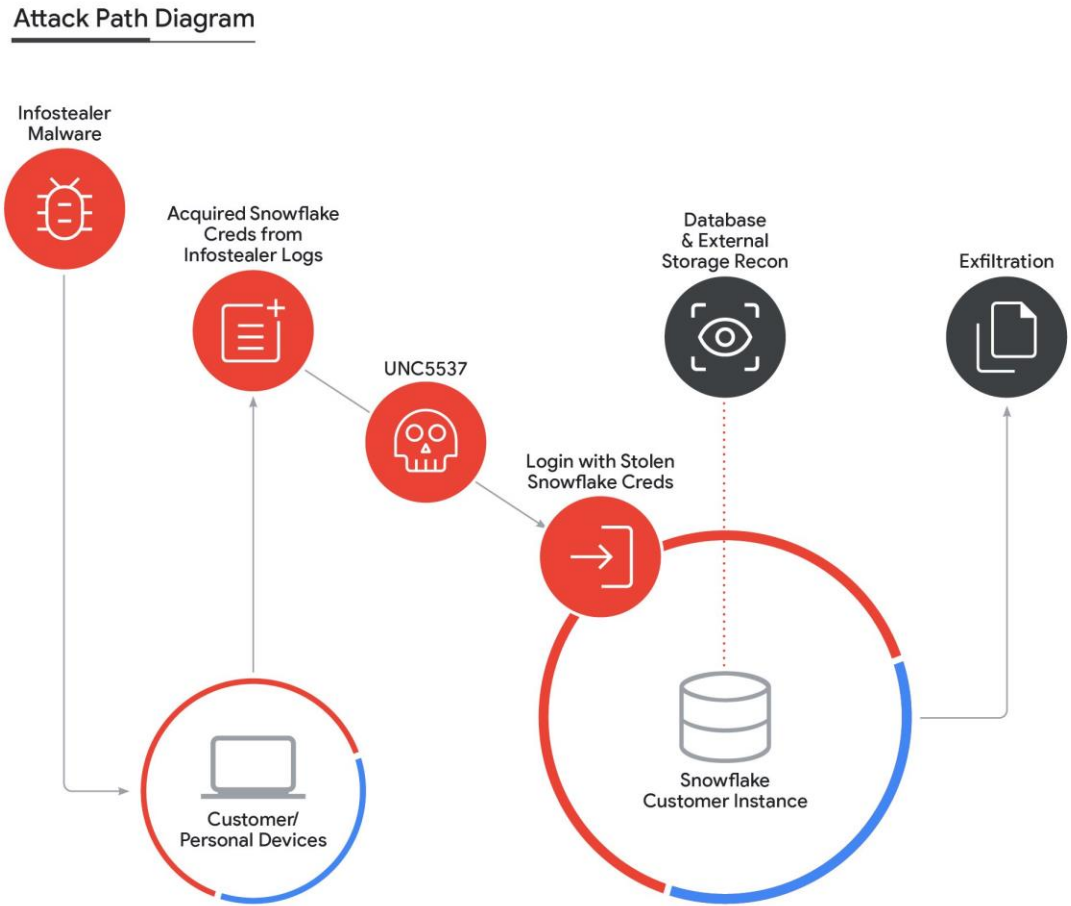
ITU-T Recommendation X.800

Access control model depends on business model and related requirements

Why Access Control

- Important Security Measure to prevent unwanted access
- Protects the confidentiality and integrity

- Example for missing/wrong access control:
  - In April 2024, the cloud platform Snowflake announced a data breach affecting major corporations like AT&T, Ticketmaster, and Santander Bank, leading to millions of users data being stolen and leaked online for sale.



Source: https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion

Lessons Learned

- Credentials used by UNC5537 came from infostealer malware dating back to 2020.
- Key factors in the threat campaign's success:
  - No multi-factor authentication on affected accounts.
  - Stolen credentials remained valid for years without rotation.
  - Lack of network allow lists for trusted access on Snowflake instances.

Access Control Requirements

- Confidential and reliable authentication BEFORE resource access
- Granular assignment of permission
- Need-to-know principle
  - Only access to information that is directly required for the fulfilment of a specific task of this person
  - Don´t forget to delete permissions if no longer needed!
- Default-To-No-Access
  - Resource access is explicitly forbidden unless it is specifically allowed.

Access Control basic Vocabs

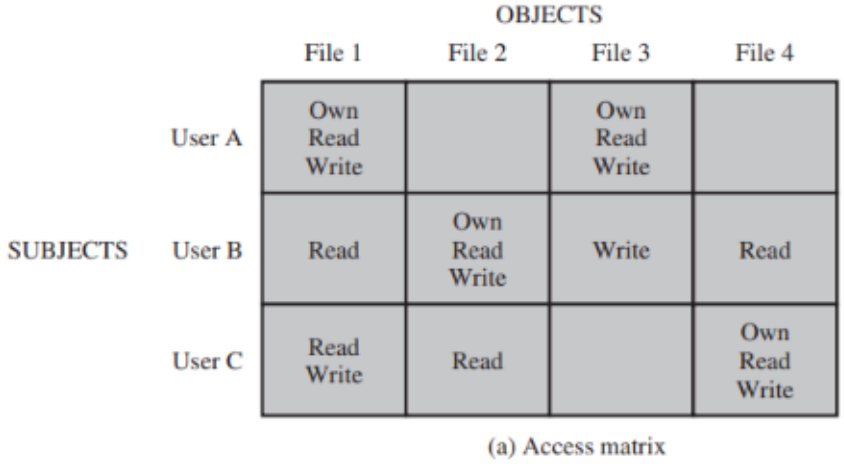
- Subjects:
  - An entity capable of accessing resources
  - Examples: an user, a system process, or an application

- Objects:
  - The resources that subjects wish to access
  - Examples: files, databases, records to network devices, memory locations, and even specific data bits

- Access Rights:
  - Define the ways in which a subject can interact with an object
  - Common access rights include read, write, execute, delete, and create

Discretionary Access Control (DAC)

- Access is based on:
  - The identity of the requestor
  - The rules set by the resource owner
- Basically: Resource owner determines access rights for each other user
- Advantages:
  - Flexible
  - User-friendly
- Disadvantages:
  - Risky if not managed properly
  - Complex to manage in big companies

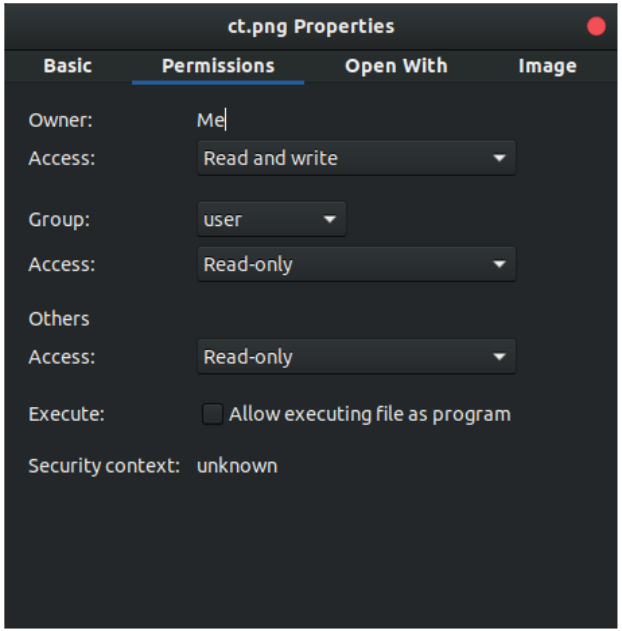


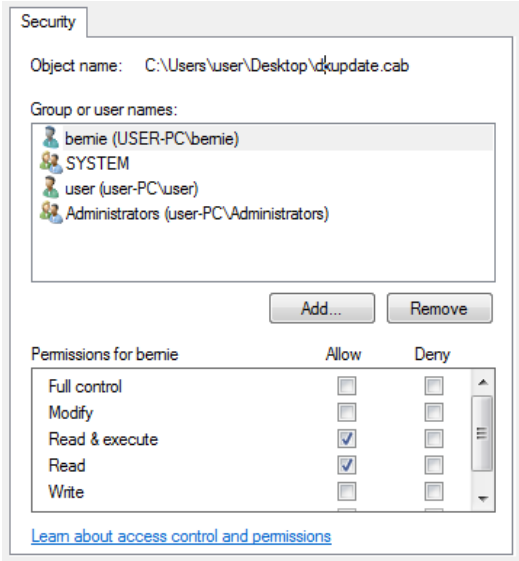
		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

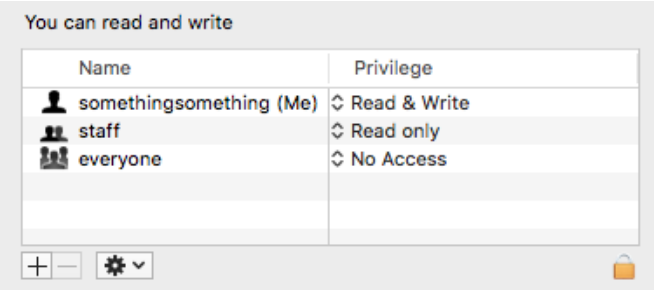
(a) Access matrix

Discretionary Access Control (DAC)

- Used in most operating systems







Mandatory Access Control (MAC)

- Access is based on:
  - Security labels (sensitivity of resources) like public, confidential, secret, top secret
  - Clearance (eligibility of users) of subjects
  - Compare: which clearance can access which security label
- Central administration instance assigns access rights
- Access for the subject is only possible if it is (at least) classified for the protection level of the object (or higher)!
- Usage: High sensible Data
  - E.g. Military or government

Mandatory Access Control (MAC)

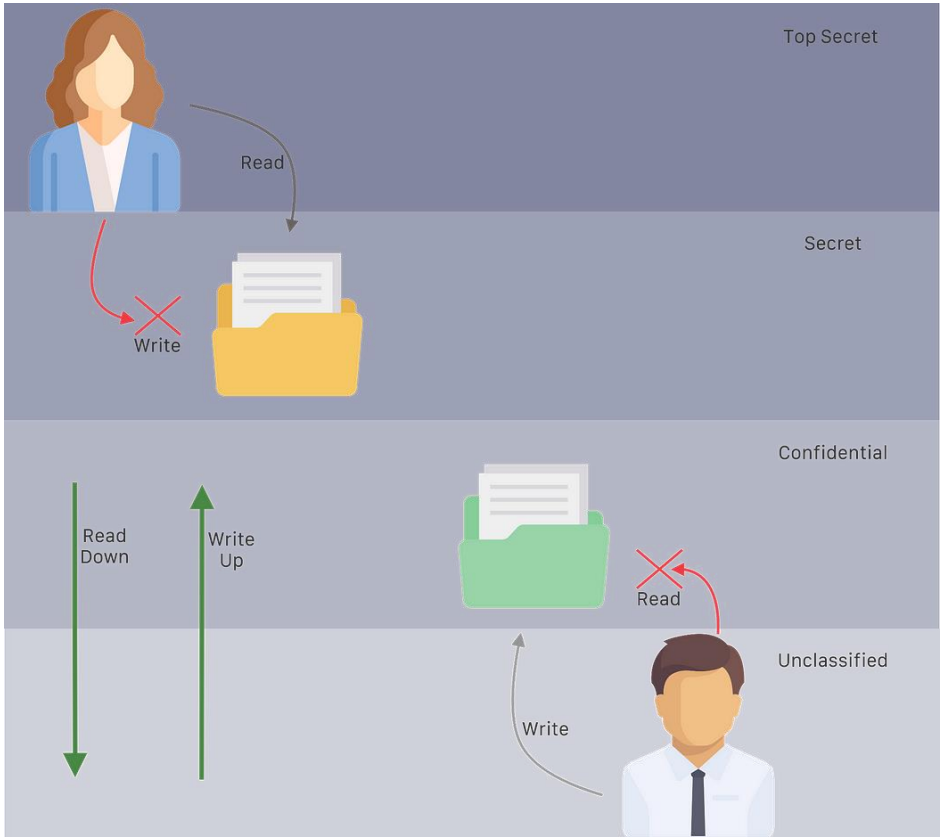
- Advantages
  - Highly secure
  - Used for secure environments like e.g. military or government
- Disadvantages:
  - Not flexible, troublesome in environments where flexibility is needed
  - Complex to maintain
- Protection goals: Integrity and Confidentiality
- Two different Subtypes
  - Bell-LaPadula
  - Biba

Bell-LaPadula

- Protection goal: Confidentiality
- Classifies subjects and objects
- Based on three rules:
  - Simple Security Rule or No Read Up Rule
    - A subject at a certain security level has no read access to objects at a higher security level.
  - *-Property Rule(Star Property Rule) or No Write Down Rule
    - A subject, at a given protection level, has no write permission to objects at a lower protection level.
  - Strong Star Property Rule
    - Read and write permissions for subjects are only granted to objects of the same protection level.

Bell-LaPadula

- Example for usage:
  - Military:
    Operative Plans are Secret
    Solders are Confidential
  - No Read Up:
    Solder cannot read up and so not read any secret information
  - No Write Down:
    Solder cannot accidentally write any secret information into public documents



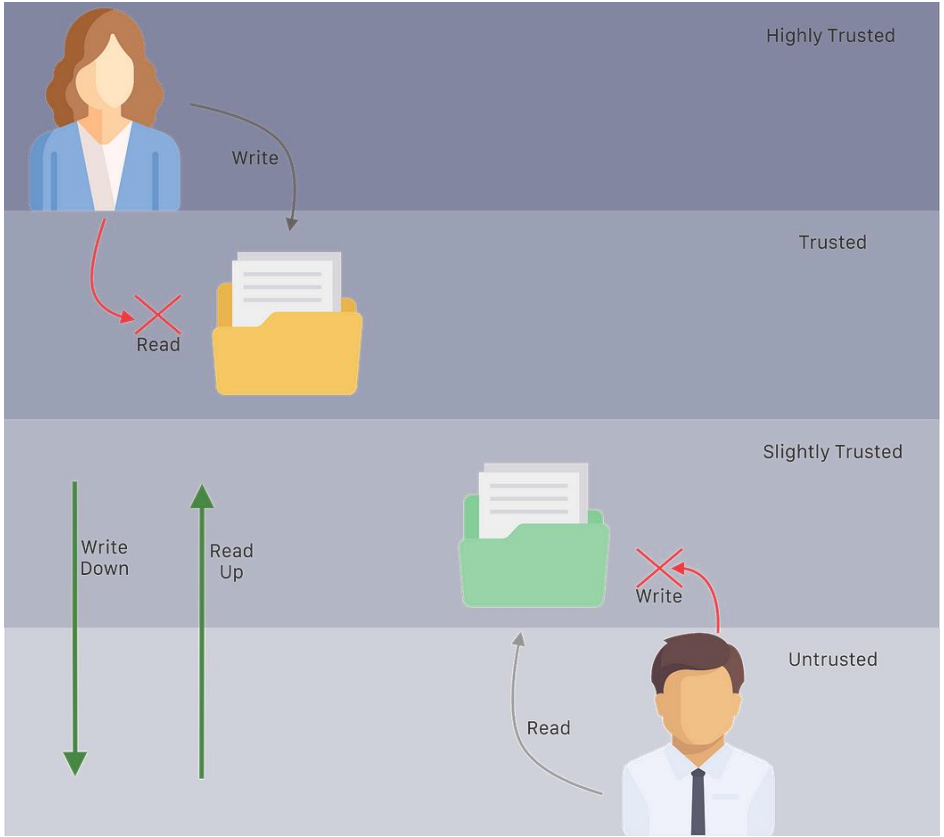
Source: https://medium.com/@kristellefeghali/biba-and-bell-lapadula-cybersecurity-models-630eed6a83f5

Biba

- Opposite of Bell-LaPadula
- Protection goal: Integrity
- Classifies subjects and objects
- Based on two rules:
  - No Read Down Rule:
    - A subject that is on a certain protection level has no read access to an object that is on a lower protection level (Simple-Integrity Axiom).
  - No Write Up Rule:
    - A subject at a certain protection level has no write permission to an object at a higher protection level (*-Integrity Axiom).

Biba

- Example for usage:
  - Trainee in Hospital
    Trainee is Slightly Trusted
    Patients treatment plans are trusted
  - No Write Up
    Trainees should not be able to change patients treatment plan
  - No Read Down
    Trainee should not read (untrusted) internal notes or not checked results of tests that could include wrong information



Source: https://medium.com/@kristellefeghali/biba-and-bell-lapadula-cybersecurity-models-630eed6a83f5

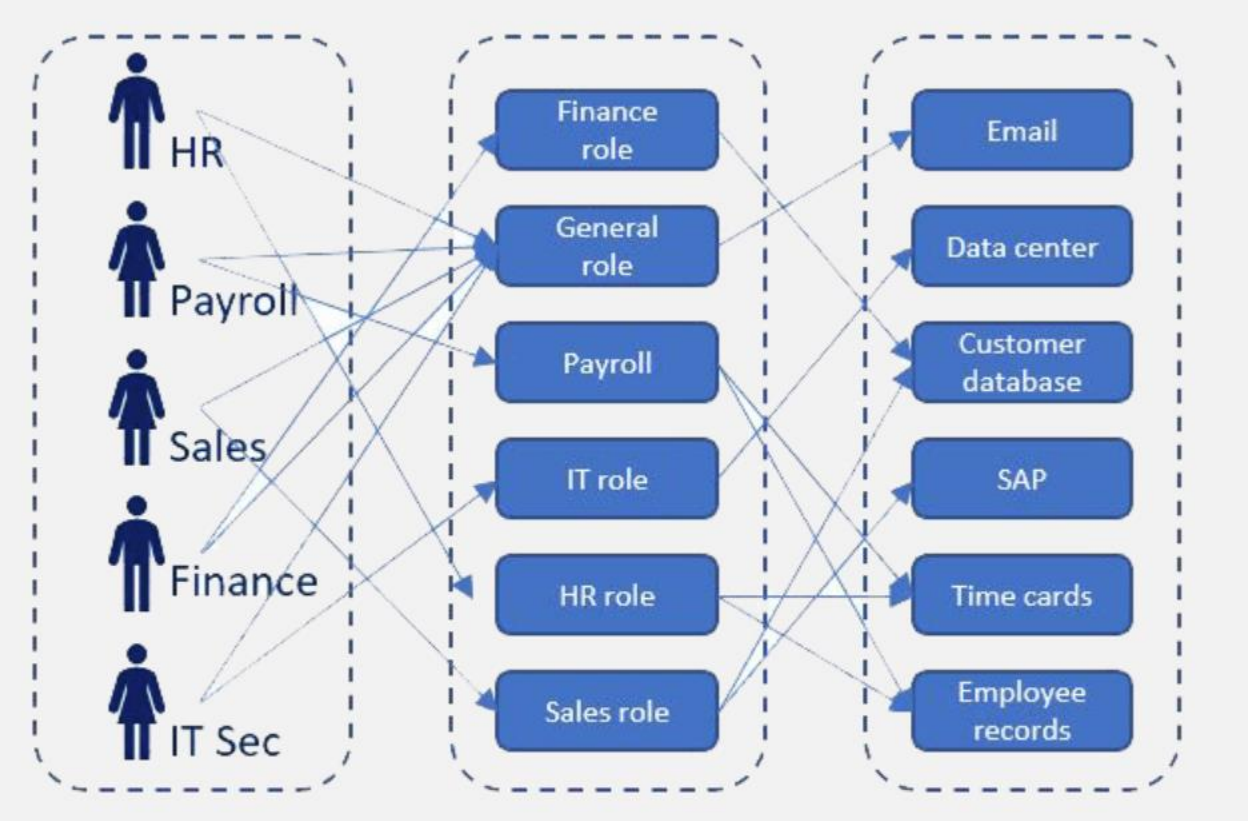
Role based Access Control (RBAC)

- Access is based on:
  - User's roles: Users are grouped into roles
  - Permissions of these roles based on Access Control Lists (ACLs)
- Roles can be used for e.g. departments or projects
- Less individual than DAC, less restrictive than MAC
- Usage:
  - Big organizations
  - Classical: usage of Active Directory groups as roles

Role based Access Control (RBAC)

- Advantages:
  - Central management
  - Scalability
  - Reduced administration effort
- Disadvantages:
  - Risky: RBAC requires careful role definition and regular updates to avoid privilege creep
  - Unflexible in special cases

Role based Access Control (RBAC) - Example



Source: https://bettercloud.b-cdn.net/wp-content/uploads/sites/3/2021/01/Screen-Shot-2021-01-08-at-10.41.02-AM.png